

常见文件密码破解

一、简介

在我们日常办公中，会遇到压缩文件，如 .zip、.rar、.7z 或者文档文件，如 .doc、.pdf 文件，被加密无法访问。或者自己之前加密过，隔段时间忘记了。

遇到这种情况，可以使用 John the Ripper 加 hashcat 两个工具进行暴力破解。

原理是，John the Ripper 获取到加密文件的hash码，然后使用 hashcat 对hash码进行暴力破解

hashcat支持使用GPU进行暴力破解，效率和性能效果较高

二、工具介绍

(2.1) John the Ripper

Ripper公司旗下的一款产品，是一款免费的密码破解工具，默认会集成在Linux的kail发行版本中。

Rippe支持目前大多数的加密算法，如DES、MD4、MD5等。它支持多种不同类型的系统架构，包括 Unix、Linux、Windows、DOS模式、BeOS和OpenVMS。

john最常见用于破解MySQL数据库内的md5加盐密码以及不够牢固的Unix/Linux系统密码

2.1.1 官网地址

<https://www.openwall.com/john/>

2.1.2 命令参数

john命令的具体参数选项如下表：

选 项	描 述
-single	single crack模式，使用配置文件中的规则进行破解
--wordlist=FILE-stdin	字典模式，从 FILE或标准输入中读取词汇
-rules	打开字典模式的词汇表切分规则
- incremental[=MODE]	使用增量模式
-external=MODE	打开外部模式或单词过滤，使用 [List.External:MODE]节中定义的外部函数
-stdout[=LENGTH]	不进行破解，仅仅把生成的、要测试是否为口令的词汇输出到标准输出上
-restore[=NAME]	恢复被中断的破解过程，从指定文件或默认为 \$JOHN/john.rec的文件中读取破解过程的状态信息
-session=NAME	将新的破解会话命名为 NAME，该选项用于会话中断恢复和同时运行多个破解实例的情况

选项	描述
-status[=NAME]	显示会话状态
-make-charset=FILE	生成一个字符集文件，覆盖 FILE文件，用于增量模式
-show	显示已破解口令
-test	进行基准测试
-users=[-]LOGIN	UID[,...]
-groups=[-]GID[,...]	对指定用户组的账户进行破解，减号表示反向操作，说明对列出组之外的账户进行破解。
-shells=[-]SHELL[,...]	对使用指定 shell的账户进行操作，减号表示反向操作
-salts=[-]COUNT	至少对 COUNT口令加载加盐，减号表示反向操作
-format=NAME	指定密文格式名称，为 DES/BSDI/MD5/BF/AFS/LM之一
-save-memory=LEVEL	设置内存节省模式，当内存不多时选用这个选项。 LEVEL取值在 1~3之间

2.1.3 范例命令

```
cp /etc/shadow shadow0      #复制密码文件
john --wordlist=/usr/share/john/password.list shadow0      #john使用字典内的密码破解密码文件
john --show password      #查看爆破结果
```

(2.2) Hashcat

Hashcat号称宇宙最强密码破解工具，其是一款开源软件，有针对Windows、Mac和Linux的版本，支持CPU、GPU、APU、DSP和FPGA等多种计算核心，支持多种hash散列算法，支持对rar、office、pdf、windows账户、wifi等多种密码的破解

hashcat作用就是破解hash码

2.2.1 官网地址

<https://hashcat.net/hashcat/>

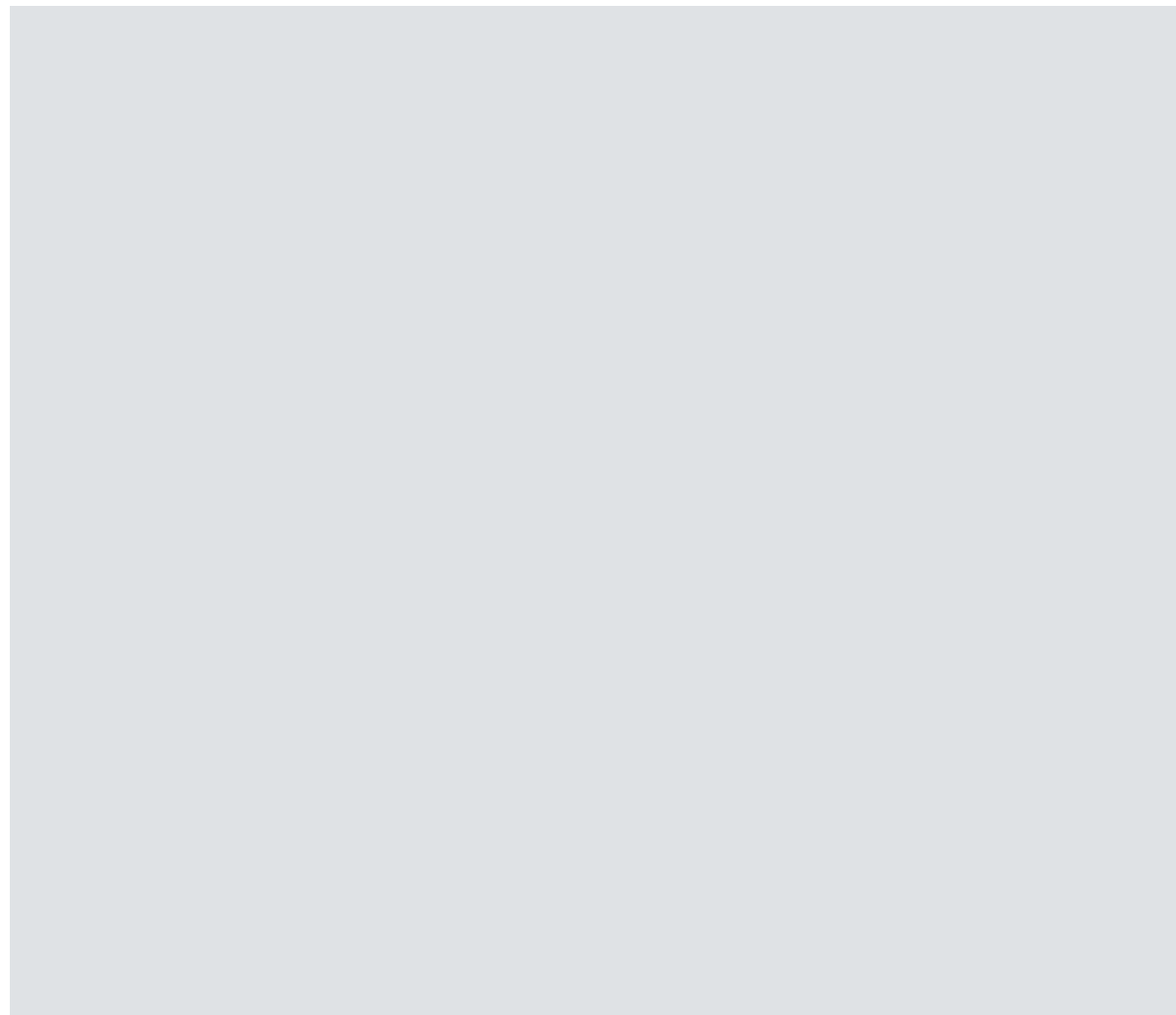
2.2.2 常用参数

```
-a  指定要使用的破解模式，其值参考后面对参数。“-a 0”字典攻击，“-a 1”组合攻击；“-a 3”掩码攻击。
-m  指定要破解的hash类型，如果不指定类型，则默认是MD5
-o  指定破解成功后的hash及所对应的明文密码的存放位置，可以用它把破解成功的hash写到指定的文件中
--force  忽略破解过程中的警告信息，跑单条hash可能需要加上此选项
--show  显示已经破解的hash及该hash所对应的明文
--increment  启用增量破解模式，你可以利用此模式让hashcat在指定的密码长度范围内执行破解过程
--increment-min  密码最小长度，后面直接等于一个整数即可，配置increment模式一起使用
--increment-max  密码最大长度，同上
--outfile-format  指定破解结果的输出格式id，默认是3
--username  忽略hash文件中的指定的用户名，在破解linux系统用户密码hash可能会用到
--remove  删除已被破解成功的hash
-r  使用自定义破解规则
```

- I 查看当前能用于破解计算的设备，当主机存在核显和显卡时，需要先执行此参数，然后-d选择显卡的编号
- d 选择用于破解计算的设备号，通常是显卡的编号

2.2.3 hash类型编号

关于 -m 参数指定要破解的hash类型，需要通过john得到hash编码后，根据得到的hash编码判断需要制定那种hash类型。可以在下表，或者官方文档https://hashcat.net/wiki/doku.php?id=example_hashes 对照hash编码找到对应的hash类型编号



2.2.4 掩码设置

这里列一下常见的掩码字符集

l		abcdefghijklmnopqrstuvwxyz	纯小写字母
u		ABCDEFGHIJKLMNOPQRSTUVWXYZ	纯大写字母
d		0123456789	纯数字
h		0123456789abcdef	常见小写字母和数字
H		0123456789ABCDEF	常见大写字母和数字
s		!"#\$%&'()*+,-./:;<=>?@[\\]^_`{ }~	特殊字符
a		?l?u?d?s	键盘上所有可见的字符
b		0x00 - 0xff	可能是用来匹配像空格这种密码的

下面举几个简单的例子来了解一下掩码的设置

八位数字密码: ?d?d?d?d?d?d?d?d
八位未知密码: ?a?a?a?a?a?a?a?a
前四位为大写字母, 后面四位为数字: ?u?u?u?u?d?d?d?d
前四位为数字或者是小写字母, 后四位为大写字母或者数字: ?h?h?h?h?H?H?H?H
前三个字符未知, 中间为admin, 后三位未知: ?a?a?admin?a?a?a
6-8位数字密码: --increment --increment-min 6 --increment-max 8 ?1?1?1?1?1?1?1
6-8位数字+小写字母密码: --increment --increment-min 6 --increment-max 8 ?h?h?h?h?h?h?h?h

如果我们想设置字符集为: abcd123456!@-+, 那该怎么做呢。这就需要用到自定义字符集这个参数了, hashcat支持用户最多定义4组字符集

```
--custom-charset1 [chars]等价于 -1  
--custom-charset2 [chars]等价于 -2  
--custom-charset3 [chars]等价于 -3  
--custom-charset4 [chars]等价于 -4  
在掩码中用?1、?2、?3、?4来表示。
```

再来举几个例子:

```
--custom-charset1 abcd123456!@-+。然后我们就可以用"?1"去表示这个字符集了  
--custom-charset2 ?1?d, 这里和?2就等价于?h  
-1 ?d?1?u, 那么?1就表示数字+小写字母+大写字母, 也可写作: --custom-charset1 ?d?1?u  
-3 abcdef -4 123456 那么?3?3?3?3?4?4?4?4就表示为前四位可能是“abcdef”, 后四位可能是“123456”
```

综上, 假设破解密码是6位, 没有特殊字符, 那么可以这样来执行hashcat:

```
hashcat -a 3 -m 13000 -1 ?1?u?d 【要破解的hash码】 --increment --increment-min 1 --  
increment-max 6 ?1?1?1?1?1?1
```

2.2.5 字典破解

hashcat默认用自己的动态密码破解方式, 但可以使用 -a 0 参数内容, 使用字典, 如下命令:

```
hashcat64.exe -a 0 hash.txt c:\dict\password.txt -o result.txt
```

2.2.6 常见破解类型

- 1.MySql4.1/5的PASSWORD函数
- 2.sha512crypt \$6\$, SHA512 (Unix)破解 (即/etc/shadow文件内的密码密文)
- 3.Windows NT-hash, LM-hash破解 (可以用saminside获取NT-hash,LM-hash的值)
- 4.mssql的密码
- 5.wordpress密码hash破解 (具体加密脚本在 ./wp-includes/class-phpass.php 的 HashPassword 函数)
- 6.discuz用户密码hash破解 (其密码加密方式md5(md5(\$pass).\$salt))
- 7.破解RAR、zip、7z压缩密码 (使用john获取hash)
- 8.破解office密码 (使用john获取hash)
- 9.破解WIFI密码

- 9.1 破解wifi密码，需要先把我们的握手包转化为hccapx格式，现在最新版的hashcat只支持hccapx格式了，以前的hccap格式已经不支持了。官方在线转化握手包为hccapx格式文件<https://hashcat.net/cap2hccapx/>
- 9.2 拿到hccapx格式文件后，执行命令hashcat64.exe -a 3 -m 2500 1.hccapx

2.2.7 其他建议

1. 对于破解过的hash值，用 hashcat64.exe hash --show 查看结果
2. 所有的hash破解结果都在hashcat.potfile文件中
3. 如果破解的时间太长，可以按s键可以查看破解的状态，p键暂停，r键继续破解，q键退出破解。
4. 在使用GPU模式进行破解时，可以使用-O参数自动进行优化
5. 在实际破解中的建议，如果我们盲目的去破解，会占用我们大量的时间和资源

1. 首先走一遍常用的弱口令字典
2. 组合密码，如：zhang1999，用姓氏和出生年组合，当然也可以用其它的组合，这里举个例子而已
3. 把常用的掩码组合整理起来放在masks中的.hcmask文件中，然后让它自动加载破解
4. 如果实在不行，你可以尝试低位数的所有组合去跑，不过不建议太高位数的组合去破解，因为如果对方设置的密码很复杂的话，到头来你密码没有破解到，却浪费了大量的时间和资源，得不偿失

6. HashCat参数优化

考虑到hashcat的破解速度以及资源的分配，我们可以对一些参数进行配置

1.Workload tuning 负载调优。

该参数支持的值为1,8,40,80,160

--gpu-accel 160 可以让GPU发挥最大性能。

2.Gpu loops 负载微调

该参数支持的值的范围是8-1024（有些算法只支持到1000）。

--gpu-loops 1024 可以让GPU发挥最大性能。

3.Segment size 字典缓存大小

该参数是设置内存缓存的大小，作用是将字典放入内存缓存以加快字典破解速度，默认为32MB，可以根据自身内存情况进行设置，当然是越大越快了。

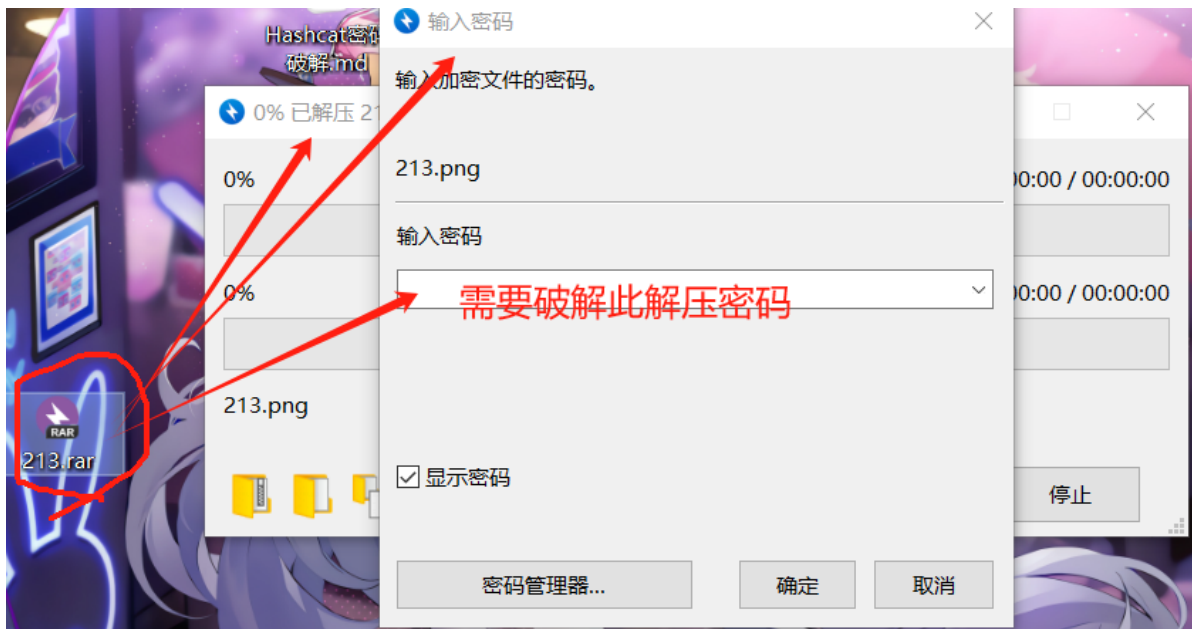
--segment-size 512 可以提高大字典破解的速度。

三、破解实战

(3.1) 破解rar压缩文件密码

3.1.1 文件描述

当前有个加密压缩包 213.rar，我们不知道解压密码，需要进行破解，如下图所示：



3.1.2 解码步骤

• 3.1.2.1 利用john the ripper 得到加密rar文件的hash码

[1] windows操作系统下，打开cmd命令行，进入john安装目录下的run目录。或者直接进入john安装目录下的run目录然后覆盖文件路径，输入cmd。

[2] 在cmd窗口中输出命令，拿到加密rar文件的hash码

```
#rar2john.exe [加密rar文件路径]
rar2john.exe c:\Users\soft-\Desktop\213.rar
```

```
C:\soft\john\john-1.9.0-win64\run>rar2john.exe c:\Users\soft-\Desktop\213.rar
c:\Users\soft-\Desktop\213.rar:$rar5$16$ee01f7b78324e3dccc9dfca5167f6ca0$15$86c9918e8639df879cf472de23b6fffb7$8$d59a03e5aa8d926d
C:\soft\john\john-1.9.0-win64\run>
```

[3] 复制john输出的hash码(前面文件路径不用复制)

```
$rar5$16$ee01f7b78324e3dccc9dfca5167f6ca0$15$86c9918e8639df879cf472de23b6fffb7$8$d59a03e5aa8d926d
```

• 3.1.1.2 使用hashcat对hash码进行解密

[1] 步骤(1)中拿到的hash码，对比hashcat中的hash类型编号，可以查到编号为13000

12400	BSDI Crypt, Extended DES	..9G..8147mpcKT8g0U.
12500	RAR3-hp	\$RAR3\$*0*45109af8ab5f297a*adbfc5385d7a40373e8f77d7b89d317
12600	ColdFusion 10+	ae9edab5653f09c4c63e559a5e967b4c112273bc6bd84525e630a3f9028dcb:5136256866783773345747837828104107068
12700	Blockchain, My Wallet	\$blockchain\$2885420055827231730710301348670802335e45a6f5f631113cb1148a6e96ce645ac69881625a115fd35256636
12800	MS-AzureSync PBKDF2-HMAC-SHA256	v1:PPH1_MD4,84840328224366186645,100,005a491d8bf3715085d69f934eef7fb19a15ffc233b5382d9827910bc32f3506
12900	Android FDE (Samsung DEK)	38421854118412625768408160477112384218541184126257684081604771129b6258eb22fc8b9d08e04e6450f72b98725d7c
13000	RAR5	\$rar5\$16\$7457556751880762:265582327032280\$15\$f8b4064de34ac02ecabfe9abdf93ded6a\$8\$984383438340f7c754
13100	Kerberos 5, etype 23, TGS-REP	\$krb5tgs\$23\$*user\$realm\$test/spn*\$63386d22d359fe42230300d56852c9eb\$891ad31d09ab89c6b3b8c5e5de6c06a7f49fd55
13200	AxCrypt 1	\$axcrypt\$*1*10000*aaf4a5b4a7185551fea2585ed69fe246*45c616e901e48c6cac7ff14e8cd99113393be259c595325e
13300	AxCrypt 1 in-memory SHA1 13	\$axcrypt_sha1\$b89eaac7e61417341b710b727768294d0e6a277b

[2] windows操作系统下，打开cmd命令行，进入hashcat安装目录下的run目录。或者直接进入hashcat安装目录然后覆盖文件路径，输入cmd

[3] cmd窗口执行命令，查看当前主机使用的解密设备，选择显卡设备编号：

```
hashcat -I
```

如下图所示，显卡设备编号为1

```

OpenCL Info:
=====
OpenCL Platform ID #1
Vendor...: NVIDIA Corporation
Name....: NVIDIA CUDA
Version..: OpenCL 3.0 CUDA 11.7.102
Backend Device ID #1
Type.....: GPU
Vendor ID...: 32
Vendor.....: NVIDIA Corporation
Name.....: NVIDIA GeForce RTX 3050 Ti Laptop GPU
Version....: OpenCL 3.0 CUDA
Processor(s)...: 20
Clock.....: 1485
Memory.Total...: 4095 MB (limited to 1023 MB allocatable in one block)
Memory.Free...: 3520 MB
Local.Memory...: 48 KB
OpenCL.Version.: OpenCL C 1.2
Driver.Version.: 517.20
PCI.Addr.BDF...: 01:00.0

OpenCL Platform ID #2
Vendor...: Intel(R) Corporation
Name....: Intel(R) OpenCL HD Graphics
Version..: OpenCL 3.0
Backend Device ID #2
Type.....: GPU
Vendor ID...: 8
Vendor.....: Intel(R) Corporation
Name.....: Intel(R) UHD Graphics
Version....: OpenCL 3.0 NEO
Processor(s)...: 16

```

显卡 编号 1

核显 编号 2

[4] 在cmd窗口中执行命令，hash类型编号为13000选择编号为1的设备（显卡）进行解密，解密的密码输出到桌面 passwd.txt：

```

hashcat -m 13000 -a 3
$rar5$16$ee01f7b78324e3dccc9dfca5167f6ca0$15$86c9918e8639df879cf472de23b6ffb
7$8$d59a03e5aa8d926d -d 1 -o c:\Users\soft\Desktop\passwd.txt

```

等待执行完成

```

Approaching final keypace - workload adjusted.

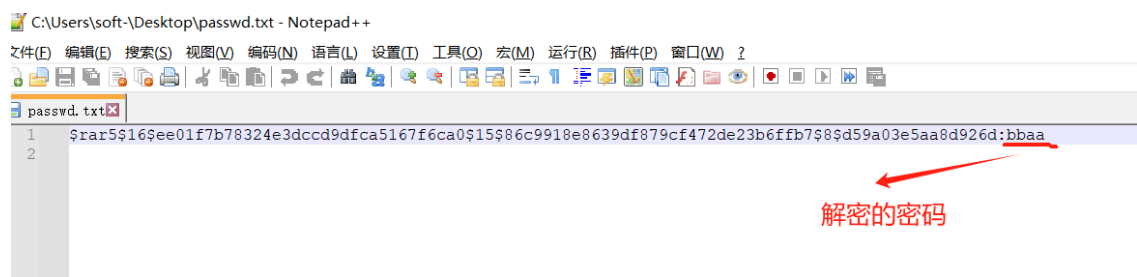
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13000 (RAR5)
Hash.Target.....: $rar5$16$ee01f7b78324e3dccc9dfca5167f6ca0$15$86c991...8d926d
Time.Started....: Thu Apr 25 11:53:40 2024 (1 min, 11 secs)
Time.Estimated...: Thu Apr 25 11:54:51 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Mask.....: ?1?2?2?2 [4]
Guess.Charset...: -1 ?1?d?u, -2 ?1?d, -3 ?1?d*!$@_, -4 Undefined
Guess.Queue.....: 4/15 (26.67%)
Speed.#1.....: 21236 H/s (1.01ms) @ Accel:32 Loops:64 Thr:256 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1504656/2892672 (52.02%)
Rejected.....: 0/1504656 (0.00%)
Restore.Point...: 23328/46656 (50.00%)
Restore.Sub.#1...: Salt:0 Amplifier:4-5 Iteration:32768-32799
Candidate.Engine.: Device Generator
Candidates.#1...: barv -> bq6
Hardware.Mon.#1..: Temp: 84c Util: 95% Core:1875MHz Mem:5989MHz Bus:8

Started: Thu Apr 25 11:53:12 2024
Stopped: Thu Apr 25 11:54:52 2024

C:\soft\hashcat-6.2.6>

```

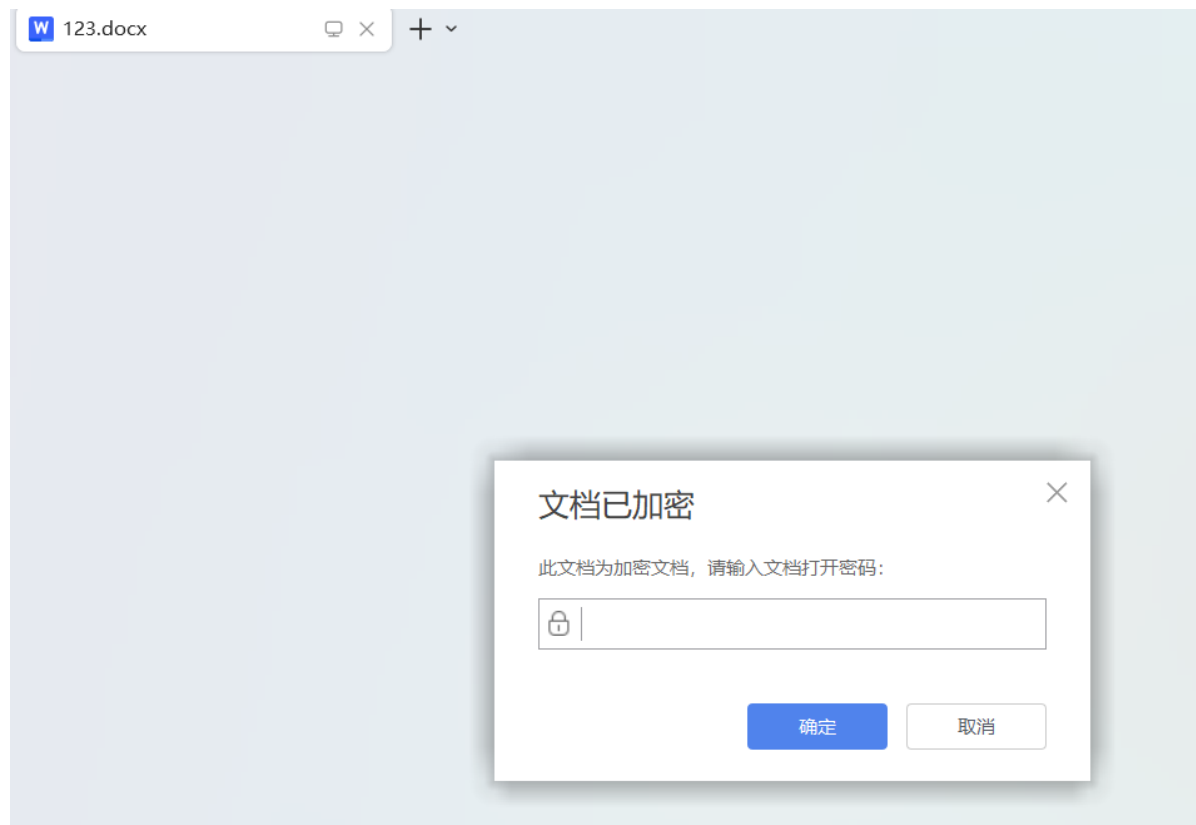
[5] 最后在桌面的passwd.txt文件里面查看的解密的密码



(3.2)破解DOC文档密码

3.2.1 文件描述

docx文件打开需要密码，如下图



3.2.2 解码步骤

和rar解码一样，john使用命令 `office2john.py [文档路径]` 拿到hash码

```
C:\soft\john\john-1.9.0-win64\run>office2john.py 123.docx
123.docx:$office$*2007*20*128*16*5734c328609653d8425e1aa7c74400a8*3a09eab0a026b72e482acdeffb9c0ff9*f9f9b7b1813065b60483d
d684f9569806d8ae01f
```

根据hash码拿到对照的hashcat类型编码后，使用hashcat进行解密